DRAFT — PENDING OWNER APPROVAL

AutoClip Information Security Policy — Candidate

Document ID: AUTOCLIP-SEC-POL-CANDIDATE **Version:** Draft 1.1 (candidate; not an official version number) **Status:** DRAFT — PENDING OWNER APPROVAL **Prepared:** 2026-11-02 **Accountable business operator:** 56.151.919 DIOGO NASCIMENTO DOS SANTOS, MEI holder; contact: diogos.nascimento@outlook.com (monitoring not verified) **Approver / effective date:** PENDING OWNER DECISION

AutoClip is the trade name of **56.151.919 DIOGO NASCIMENTO DOS SANTOS**, an individual micro-entrepreneur (MEI) registered in Brazil (CNPJ **56.151.919/0001-30**), based in Rio de Janeiro/RJ. The business is operated by the MEI holder. Contact: **diogos.nascimento@outlook.com**. This contact is owner-provided; mailbox monitoring has not been independently verified. This candidate is a consolidation for review. It does not replace, approve, publish, or amend `apps/web/public/security-policy.html` or the historical PDFs. Those artifacts disagree on version and approval status. Do not represent this candidate as currently effective.

1. Purpose and scope

This policy candidate sets security requirements for AutoClip application code, identity and access, databases, object storage, backend functions, workers, operational accounts, information, and service providers. It applies to development, test, staging and production environments. Production and provider controls must be verified in their actual environments; local code is not proof of deployment.

2. Governance and responsibility

The project owner is accountable for approving this policy, assigning responsible operators, approving changes within their authority, and retaining review evidence. Engineering personnel and service providers must use information only for assigned purposes, protect credentials, follow least privilege, and report suspected incidents through an owner-confirmed channel. Named role holders, delegates, contact-channel monitoring, and approval date remain to be confirmed.

3. Identity, authorization and tenant boundaries

Access shall be based on authenticated identities, least privilege, role authorization and workspace

membership. Database RLS, RPC authorization, backend checks, foreign keys and Storage rules must consistently enforce workspace boundaries. Local migrations and tests provide local evidence for parts of this design; the active Cloud grants, policies, deployed function bodies and runtime enforcement have not been established by this candidate. Privileged server credentials must not be placed in browser-delivered code.

4. Credential and OAuth protection

OAuth credentials shall be restricted to trusted server-side processing, encrypted before persistence where implemented, excluded from logs and client responses, and associated with the correct connection and workspace. The local shared crypto implementation uses AES-GCM and has synthetic tests. Gate 3.19.3 also recorded that a legacy direct writer could bypass the newer compare-and-swap path; the complete single-writer guarantee therefore remains unproven until old writers are drained or made compatible and verified. Secret provisioning, key access/rotation, deployed code, provider telemetry, TikTok Shop token semantics and production behavior remain subject to separate verification. Login Kit and TikTok Shop authorization contracts must be handled as distinct until authoritative product-specific evidence establishes otherwise.

5. Data and media protection

AutoClip shall collect only data necessary for user-requested account connection, workspace operation, media handling, scheduling, publication, security and support. Access to media and publication metadata shall be workspace-scoped. The local schema includes Shop product/order fields and raw JSON fields whose actual payload content and minimization are not verified. Do not enable or represent processing of unnecessary fields as approved until field-level review is complete.

6. Secure communications and encryption

Application and provider communications shall use approved HTTPS/TLS endpoints with certificate validation where applicable. The local application encrypts OAuth tokens using authenticated encryption; this does not establish encryption settings for the deployed database, backups, Storage, or provider accounts. Provider-managed encryption and actual TLS/public domain configuration require environment-specific evidence.

7. Development, changes and vulnerability management

Security-sensitive changes should receive review, targeted negative tests, dependency checks and isolated integration tests before release. Database changes require review of authorization, tenant isolation, privilege changes, locking, data preservation, compatibility and recovery. Test data should be synthetic. Historical Gate results are not current release evidence; current checks must be recorded with environment and command.

8. Logging and monitoring

Logs should support security investigation while minimizing personal information. Plaintext tokens, passwords, authorization codes, keys, full credential-bearing URLs and media content must not be intentionally recorded. Access, retention, alerting, telemetry redaction and operational log review are not proven by source policy and must be checked in deployed services.

9. Incident response

The incident runbook documents triage, containment, investigation, notification assessment, recovery and post-incident actions. Treat the process as operational only after confirming monitored contact coverage, incident lead and delegate, protected register, escalation path and a recorded exercise. No claim of continuous monitoring or completed tabletop is made here.

10. Retention, deletion and recovery

Retention periods shall be approved by data category, purpose and legal or contractual exception. Verified deletion requests must be scoped across relevant database, Storage, credentials, logs and provider systems. Media cleanup must account for shared references, pending or unknown publication state, and an approved safety period. The repository contains relevant source code and request-page text, but complete operational deletion and a comprehensive retention schedule are not verified. Gate 3.19.3 reported backup creation success but unsuccessful restore attempts; successful recovery is not established.

11. Third parties and privacy

The project must maintain a current provider/subprocessor inventory, purposes, data categories, relevant terms, access model and transfer assessment. Applicable privacy-law duties, legal bases, international transfers and data-subject request deadlines require owner and qualified legal review. This policy is not a legal opinion or certification and does not claim full LGPD compliance, ISO 27001, SOC 2, independent audit or TikTok approval.

12. Review, exceptions and approval

Review this policy at least annually and after a material change or incident. Exceptions must record scope, justification, risk, compensating controls, accountable approver, expiry and remediation. The owner must confirm the public-policy version and effective date before approval. The operator is the MEI holder named above; the controller/processor role remains processing-specific. Approval record: pending owner decision; no effective date or publication is claimed.

Evidence boundaries

Claim area	Available evidence	Boundary
Token cryptography	Local AES-GCM module and synthetic tests	Does not prove secret configuration, deployed code or Cloud data state
Workspace authorization	Local migrations/tests and historical gate reports	Does not prove current Cloud policies/grants or operational isolation
Incident response	Local runbook	Does not prove contact monitoring, delegate or exercise
Deletion and retention	Local page/source code	Does not prove all-data deletion, retention periods or deployed activation
Backup/recovery	Gate 3.19.3 local disposable rehearsal	Dump creation passed; restore failed, so recovery is not verified
OAuth	M10/M11 and local tests	Migrations not confirmed deployed; Shop contract remains distinct/unconfirmed

References

- `docs/compliance/tiktok-shop/AUTOCLIP_PERSONAL_INFORMATION_PROTECTION_STANDARD.md`
- `docs/compliance/tiktok-shop/SECURITY_CONTROL_EVIDENCE_MATRIX.md`
- `docs/compliance/tiktok-shop/DOCUMENT_INVENTORY_AND_VERSION_AUDIT.md`
- `docs/INCIDENT_RESPONSE_RUNBOOK.md`
- `docs/SECURITY_OPERATIONS.md`
- `docs/GATE_3_19_3_GO_NO_GO.md`